

SIMATS ENGINEERING

ASSESSMENT TOOL III – ERROR ANALYSIS TASK (LOW)

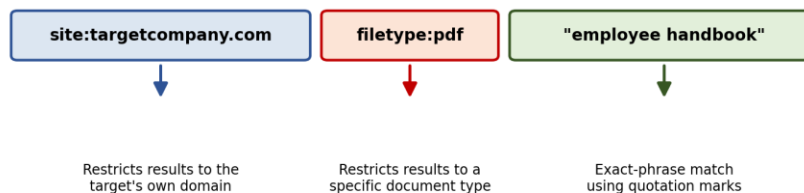
Course: Ethical Hacking for Secure Networks | CO2

Course Name: Ethical Hacking for Secure Networks	CO: CO2
Duration: 90 min	Total Marks: 50
Date: 05.08.2026	Reg. No / Name: AJAY U 192421237

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks. (BL3)

Question 1: Incorrect Google Dork Query Formulation

Anatomy of a Correctly Scoped Google Dork Query



Combined query → `site:targetcompany.com filetype:pdf "employee handbook"`

Error Identification

The student used Google dorking without any search operators such as `site:`, `filetype:`, or quotation marks for exact phrases. Plain keyword searches were entered directly into the search engine, so Google treated every word as an independent, loosely matched term instead of a query scoped to the organisation's domain or a specific file type.

Root Cause Analysis

The root cause is a lack of understanding of Google's advanced search syntax and the purpose of scoping a query before running it. Google dorking works by combining operators to narrow the search index down to a specific site, file format, page title, or URL pattern. Without these operators, the search engine returns its normal, broad web index — mixing in unrelated companies with similar names, generic blog articles,

and unrelated PDFs — because there is nothing in the query telling Google to restrict results to the target organisation. This produces noisy, low-relevance data, and because the student proceeded with analysis on this data, every downstream conclusion (technology stack, exposed documents, employee details) inherits the same inaccuracy and can misdirect the entire footprinting exercise.

Correction & Justification

- Restrict results to the target's domain: `site:targetcompany.com` — ensures every result actually belongs to the organisation being investigated.
- Restrict by file type when hunting for documents: `filetype:pdf site:targetcompany.com` — surfaces only PDF files hosted on the target domain (similarly `filetype:xlsx` or `filetype:docx` for spreadsheets and Word files).
- Use quotation marks for exact-phrase matching: `"confidential" site:targetcompany.com filetype:pdf` — forces Google to match the literal phrase instead of treating each word independently.
- Combine `intitle:` or `inurl:` to find specific page types, e.g. `intitle:"index of" site:targetcompany.com`, to look for exposed directory listings.
- Exclude irrelevant terms with the minus operator, e.g. `-inurl:careers`, to filter out noise such as job-posting pages that are not useful for the current objective.
- Corrected example query: `site:targetcompany.com filetype:pdf "employee handbook"` — this single query is scoped to the domain, the file format, and an exact phrase, giving far more precise and actionable results than the original unscoped search.

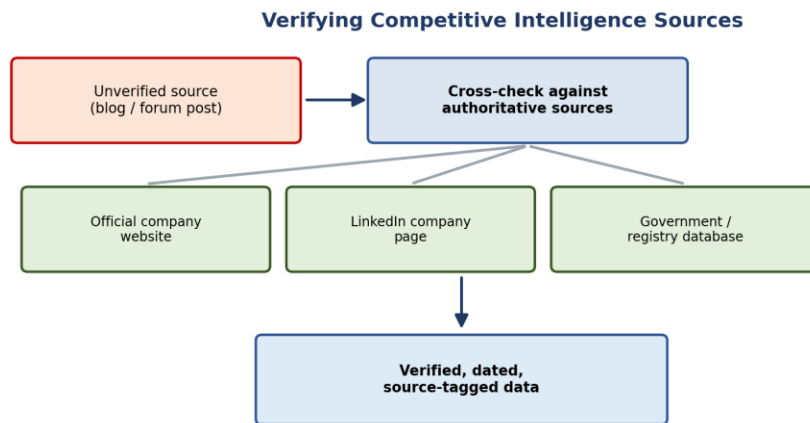
Application of Concepts

Properly scoped Google dorks are a core passive-footprinting technique because they extract intelligence without ever touching the target's own infrastructure, leaving no trace in the target's logs. Applying the corrected syntax lets the analyst reliably enumerate exposed documents, subdomains, login portals, and configuration files that the organisation may not realise are indexed publicly.

Clarity & Presentation

Documenting each operator used, the reasoning behind choosing it, and the exact query string in the final report makes the query reproducible, auditable, and easy for a reviewer to verify.

Question 2: Unverified Source Data in Competitive Intelligence



Error Identification

The student collected competitive intelligence — employee details and organisational structure — from blogs and unofficial forums without cross-checking the information against any authoritative source. The resulting dataset contained outdated employee names and an incorrect organisational hierarchy.

Root Cause Analysis

The underlying mistake is skipping source validation, one of the fundamental steps of the OSINT (open-source intelligence) process. Blogs and unofficial forums are user-generated, rarely updated, and not accountable to the organisation being profiled, so they frequently contain stale or speculative information — for example, an employee who has since left the company, or a department that has been restructured. Treating such sources as equivalent to first-party, authoritative sources conflates unverified rumour with verified fact. Because the student's subsequent analysis was built entirely on this unverified base data, every downstream decision — choosing a pretext for a social-engineering attempt, or identifying a phishing target — inherits the same inaccuracy, which can waste effort, cause incorrect attribution, or even mean targeting the wrong individual entirely.

Correction & Justification

- Cross-reference against the organisation's own website: the official 'Leadership' or 'Team' page and press releases are first-party sources maintained directly by the company and are the most authoritative record of current staff and structure.

- Use LinkedIn's company page to confirm current employees, job titles, and reporting relationships, since LinkedIn profiles are self-maintained and typically updated close to real time when someone changes role or leaves.
- Check official government or regulatory databases (company registries, SEC/MCA filings, business licence records) for legally registered officers, directors, and incorporation details, which cannot be casually altered the way a forum post can.
- Corroborate any single unofficial claim with at least two independent authoritative sources before including it in the final intelligence report — a single blog mention is treated as a lead to verify, not as a fact to report.
- Note the collection date and source next to every data point, so that time-sensitive details (such as 'current' job titles) can be re-verified before being relied upon.

Application of Concepts

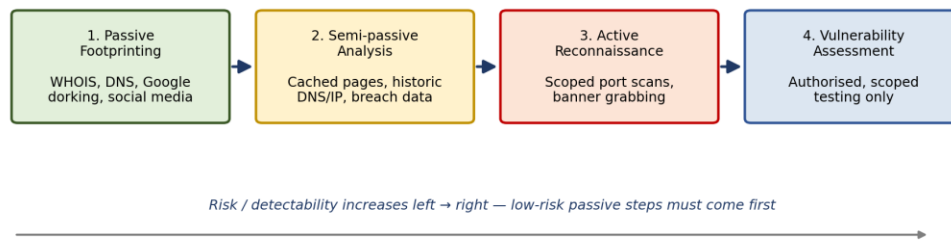
Reliable competitive intelligence directly supports the CO2 objective of identifying genuine security risks; a social-engineering pretext or spear-phishing target list built on inaccurate organisational data is far more likely to fail or to be flagged as suspicious, reducing the value of the entire assessment.

Clarity & Presentation

The final report should tag every fact with its source and confidence level (e.g., 'verified via official website' vs 'unverified, forum-sourced') so that anyone reading the intelligence summary understands how reliable each data point is.

Question 3: Skipping Passive Reconnaissance Before Active Scanning

Correct Reconnaissance Sequence



Error Identification

The student began active scanning directly against the target organisation without first performing passive footprinting steps such as a WHOIS lookup or search-engine analysis. This premature active engagement triggered detection alerts on the target's side.

Root Cause Analysis

The mistake is a failure to follow the correct reconnaissance methodology, which is structured to move from passive (no direct interaction with the target) to active (direct interaction with the target's systems) only after passive intelligence has been exhausted. Active scanning — port scans, service enumeration, vulnerability probes — sends packets directly to the target's infrastructure, and most organisations run intrusion-detection systems (IDS), firewalls, and SIEM alerting that flag unusual or unauthorised scanning traffic. By skipping the passive stage, the student not only alerted the target's security team prematurely (potentially ending the engagement or alerting adversaries in a real red-team scenario) but also lost the opportunity to use freely available, low-risk information to plan a more efficient and targeted active scan.

Correction & Justification

- Step 1 – Passive footprinting: WHOIS lookup, DNS record enumeration, Google dorking, social media and job-posting analysis, certificate-transparency log review — none of this touches the target's live systems, so it produces zero detection risk.
- Step 2 – Semi-passive analysis: reviewing publicly cached pages, historical DNS/IP data, and third-party breach or leak databases to build a fuller picture without direct probing.
- Step 3 – Active reconnaissance (only after Steps 1–2): targeted port scanning, banner grabbing, and service-version identification, scoped specifically to the hosts and services already identified

as relevant during passive research — minimising the number of packets sent and therefore the chance of triggering alerts.

- Step 4 – Vulnerability assessment / exploitation simulation, conducted only within the authorised scope and after prior steps have narrowed the target list, and typically only after obtaining explicit written authorisation.

Application of Concepts

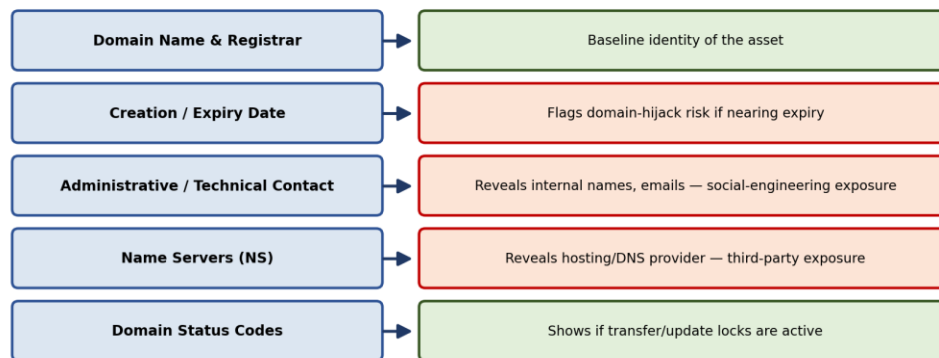
This ordering mirrors the standard footprinting-to-scanning-to-enumeration methodology taught under CO2: passive reconnaissance is critical because it is stealthy, legally lower-risk, and dramatically narrows the active-scanning scope, making later steps both faster and less detectable.

Clarity & Presentation

A reconnaissance report should clearly separate findings by phase (passive vs active) so a reviewer can see that low-risk techniques were exhausted before any direct interaction with the target began.

Question 4: Incomplete WHOIS Record Analysis

WHOIS Record — Fields and Their Security Insight



Error Identification

The student performed a WHOIS lookup but recorded only the domain name and registrar, ignoring other available fields such as the expiry date, administrative/technical contact details, and the name servers listed for the domain.

Root Cause Analysis

The mistake stems from treating WHOIS as a simple 'who owns this domain' check rather than a structured record with multiple security-relevant fields. A full WHOIS response contains several distinct data points, and omitting most of them means the student captured only a fraction of the available intelligence, missing details that directly inform both social-engineering and infrastructure-mapping activities.

Correction & Justification

- Expiry / renewal date: reveals whether a domain is close to lapsing — an expired or soon-to-expire domain is a known attack vector (domain hijacking, allowing an attacker to register it once it lapses and impersonate the organisation).
- Administrative and technical contact details: often reveal internal employee names, direct email addresses, and phone numbers that can be used (or, defensively, must be protected) — an organisation should verify these are using role-based addresses and WHOIS privacy protection rather than a named individual's personal contact.
- Name servers (NS records): indicate which DNS or hosting provider the organisation uses, which can point to third-party infrastructure that may itself have separate vulnerabilities or

misconfigurations (e.g., subdomain takeover risk if an NS entry points to a decommissioned cloud service).

- Registrar and creation date: help establish the domain's history and can flag suspicious patterns, such as a very recently created domain impersonating an established brand.
- Corrected practice: capture and document every available WHOIS field (registrant/admin/tech contact, creation date, expiry date, registrar, name servers, and domain status codes) rather than only the domain name and registrar.

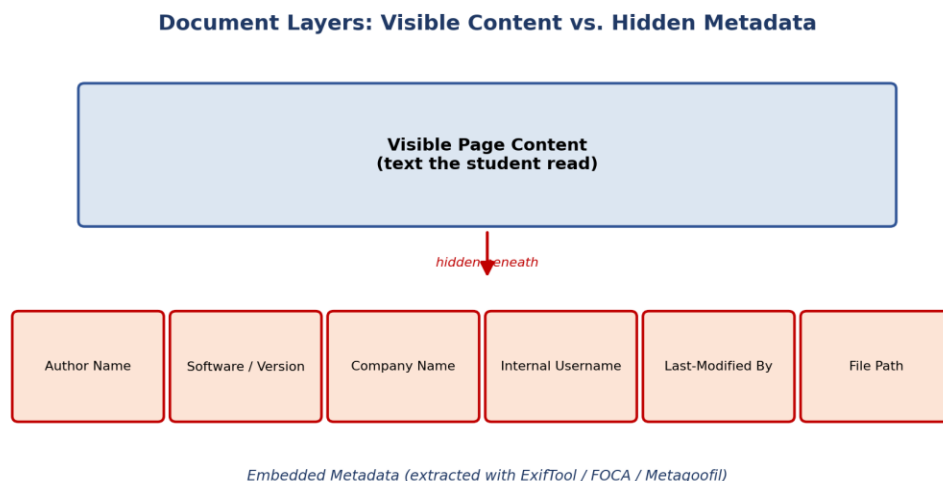
Application of Concepts

A complete WHOIS analysis feeds directly into the CO2 skill of identifying potential security risks: expiry dates flag hijacking risk, name servers flag third-party/hosting exposure, and contact fields flag social-engineering exposure — none of which would be visible from a partial record.

Clarity & Presentation

WHOIS findings are best presented as a structured field-by-field table (Field | Value | Security Implication) so each piece of information is explicitly tied to the risk it represents.

Question 5: Ignoring Embedded Metadata in Public Documents



Error Identification

The student downloaded publicly available documents from the organisation's website and reviewed only their visible content, overlooking the embedded metadata inside the files. As a result, valuable details such as author names, software versions, and internal usernames present in the metadata were missed entirely.

Root Cause Analysis

The mistake is a narrow, surface-level review of documents that ignores the fact that common office file formats (PDF, DOCX, XLSX, PPTX, and even images) store hidden metadata alongside the visible content — author name, the software and version used to create/edit the file, company name, last-modified user, template paths, and sometimes internal file-system paths or printer names. Because this metadata is not rendered when a document is opened normally, a footprinting exercise that only reads the visible page content systematically misses it, discarding a rich and easily-collected source of intelligence.

Correction & Justification

- Use a dedicated metadata-extraction tool such as ExifTool, FOCA, or Metagoofil to batch-process downloaded documents and pull out all embedded metadata fields automatically.
- For a single file, metadata can also be checked manually through the document's own 'Properties' / 'Info' panel (e.g., File > Info in Microsoft Office, or Document Properties in Adobe Acrobat).
- Aggregate results across many documents to build patterns: repeated author names indicate active employees, consistent software versions indicate the organisation's standard software stack

(useful for identifying version-specific vulnerabilities), and internal usernames or file paths can reveal naming conventions used across the organisation.

- Correct method in practice: (1) enumerate public documents via search-engine dorking (filetype:pdf, filetype:docx, etc. as in Question 1), (2) download them, (3) run them through a metadata-extraction tool, (4) tabulate the extracted fields alongside the source URL for traceability.

Application of Concepts

Metadata analysis is a recognised passive-footprinting and competitive-intelligence technique: it can reveal an organisation's software stack (helping match known CVEs to specific versions), internal usernames and naming conventions (useful for building a target list for phishing or password-guessing awareness testing), and employee names for further OSINT correlation.

Application — Ethical Use

Within an authorised assessment, this information should be used strictly to help the organisation understand its own exposure — for example, recommending that 'Remove Personal Information' or metadata-scrubbing tools be run before documents are published, and flagging outdated software versions found in metadata so they can be patched. It should never be retained beyond the scope of the engagement or used for any purpose outside the authorised assessment.

Clarity & Presentation

Findings should be presented as a metadata summary table (Document | Author | Software/Version | Other Identifiers) accompanied by a short remediation recommendation, making the security implication clear at a glance.

Code of Conduct

I, **AJAY U 192421237** (Name / Reg. No), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: **AJAY U**__